

RoundImage: Toward Secure Graphical Password Authentication via Rounded Image Selection in IoT

Xinyuan Qin, Wenjuan Li[✉], *Senior Member, IEEE*, and Philip Rosenberg

Abstract—User authentication is a basic security mechanism under Internet-of-Things (IoT) environments, which means to verify whether the logging user is legitimate or not. Due to known limitations of existing password-based authentication, graphical password is one promising solution to enhance the current user authentication process in IoT. However, it is an open question how to design a usable and robust graphical password scheme. In this work, we introduce RoundImage, a graphical password scheme that requires users to select images in rounds (e.g., three rounds) for authentication. It can resist against some typical threats, such as shoulder-surfing attacks and provide fault tolerance. In the evaluation, we set up an IoT scenario and test its performance with 100 participants. The results demonstrate the usability and potential of our scheme in a practical IoT environment.

Index Terms—Consumer Smartphone, graphical password, image selection, IoT security, shoulder-surfing attack, user authentication.

I. INTRODUCTION

USER authentication is a basic but important security mechanism—or a process to verify someone who is eligible to access services and applications according to security policies. Currently, password-based user authentication is the most widely used approach—a user has to present a valid and correct textual strings. Only a successful input can lead to the system access, but such authentication approach has well-known limitations relating to both security and usability. For example, the credentials can be easily leaked under charging attacks [29], [30] or recording attacks [6], so an attacker can use the leaked password to log into the system. Also, users are difficult to remember a complex password for a long time, due to the long-term memory limitation [22], [41] and the potential multiple password interference [27].

In order to improve the above situation, the research society proposed a promising alternative—graphical password, which requires an individual to generate their credentials by utilizing their visual capabilities on images—that is, by interacting with images [15]. This is motivated by the observation that human

beings can have a better memory over visual things, such as images than textual things [31], [35]. For example, Android Unlock is the typical usage that applies graphical password's concept into reality. It needs users to create a pattern within a 3×3 grid, by selecting 4–9 dots [27].

To interact with an image, three operations are commonly used: 1) drawing something on the image; 2) selecting something on an image; and 3) choosing image(s) from an image pool. Although a graphical-password-based authentication can provide better usability (e.g., memorability), it would be vulnerable to existing security threats similar to the traditional authentication systems. More graphical password schemes can refer to Section II. It is worth noting that most of the current graphical password schemes are vulnerable to 'hot-spot' attacks and shoulder-surfing attacks. Generally, shoulder-surfing attack is still a big threat to these schemes [42], as long as the attacker can obtain the credentials or observe how users input their credentials. Another simple instance is: Android unlock can be brute-forced (especially off-line attacking), as its password strength is only 389, 112 [2]. Therefore, it is still an open challenge on how to design a usable and robust graphical password system.

Contributions: Motivated by the literature, in this work, we aim to design a usable and robust graphical password scheme by considering one of the basic operations: that is, selecting images in rounds. In particular, we develop *RoundImage*, a graphical password scheme that asks an individual to select images with multiple rounds. The main purpose is to reduce the possibility of being monitored or observed by an attacker. For instance, the multiple selection of images can effectively reduce the success rates of shoulder-surfing attacks, as the attacker has to capture all rounds of image selection. Our contributions can be summarized as below.

- 1) We develop RoundImage, a graphical password scheme, in which users have to select image(s) in three rounds. The multiple selection rounds aim to greatly reduce the possibility of shoulder-surfing attacks to succeed. To enhance the usability, RoundImage provides fault tolerance capability, i.e., with matching rate above 75%. The concrete threshold can be adjusted in practice, and our scheme can also be deployed in a distributed environment, such as IoT.
- 2) To study the scheme performance, we first conduct a user study with 60 participants. In comparison with traditional schemes, our results indicate that our RoundImage scheme can be more effective against shoulder-surfing attacks. Then we perform additional

Received 25 May 2024; revised 3 August 2024 and 7 September 2024; accepted 15 February 2025. Date of publication 4 March 2025; date of current version 9 June 2025. (Corresponding author: Wenjuan Li.)

Xinyuan Qin is with the Department of Electronic and Information Engineering, The Hong Kong Polytechnic University, Hong Kong SAR, China.

Wenjuan Li is with the Mathematics and Information Technology, The Education University of Hong Kong, Hong Kong SAR, China (e-mail: wenjuan.li@ieee.org).

Philip Rosenberg is with the Department of Electronic Systems, Aalborg University, 9220 Aalborg, Denmark.

Digital Object Identifier 10.1109/JIOT.2025.3547816

user studies (AUS) with 40 new participants to explore its performance with two other graphical password schemes. We also discuss the guidelines about designing a graphical password system with rounded image selection.

Our work was extended from our previous version [1]; however, we made the following new contributions: 1) We improved the prototype that allows to define rounds of image selection, e.g., two rounds or three rounds; 2) We performed new user studies to investigate the scheme performance and the effect of different rounds of image selection; and 3) We also tested our prototype under an IoT environment and obtained the results that can serve as reference for graphical password implementation based on image selection.

Paper Organization: The reminder of this article is structured as follows. Section II presents relevant studies on graphical password schemes in the literature. Section III describes our proposed RoundImage with detailed steps and implementation. Section IV details our user study with result analysis. Section V presents additional studies and discusses open challenges. Lastly, Section VI concludes our work.

II. RELATED WORK

There are many graphical password schemes have been developed, which can be generally classified into the following four categories [28], [37]:

- 1) *Recognition-Based Authentication:* A user has to pick up targeted number of images from a pool.
- 2) *Pure Recall-Based Authentication:* A user has to draw something (valuable to the user-self) on a chosen image.
- 3) *Cued Recall-Based Authentication:* A user has to perform kind of selections (e.g., an object or touch region) on a chosen image.
- 4) *Hybrid Authentication System:* Such system incorporates the features from the above schemes, while it can focus more on one operation than the others.

The existing graphical password schemes can be classified into one type of the above. In the very beginning of graphical password development, most designed schemes are not hybrid. For example, Wiedenbeck et al. [40] presented *PassPoints*, a typical cued recall-based scheme, which asks an individual to pick up five touchable points on a chosen image (with order). An improved version then was proposed by Chiasson et al. [5]. The improved scheme requires an individual to choose one valid region on three selected images in an order. Jermyn et al. [9] developed a ‘draw-a-secret’ scheme, where the user can draw something (e.g., a pattern) on a chosen picture. It is worth noting that most existing schemes have not been implemented in practice, there are two typical commercialized schemes: one is *PassFaces* [33] (authenticating users based on face-image selection) and the other is Android unlock [27] on mobile devices (especially on Android devices).

Most of the current graphical password schemes in the literature are vulnerable to ‘hot-pot’ attacks and shoulder-surfing attacks. Thus, there is a rapid trend to develop kind of hybrid schemes to combine the merits from basic operations.

Hybrid Scheme: Hybrid schemes (combining different graphical password operations) have been made more efforts in order to achieve better security levels. A typical scheme is called *CD-GPS* scheme [16], which needs an individual to first select an image from an image pool and then draw something on the selected image. They designed a particular action called *click-draw* that means the user has to choose clickable squares. Such scheme has incorporated all the above graphical password operations especially their advantages. Another typical scheme is called geographical password or map-based graphical password, such as *PassMap* [38] and *RouteMap* [21]. The main idea of such schemes is asking a user to draw a pattern or select useful regions on a world map (or could be part of a world map), i.e., users have to select two locations on *PassMap* and create a memorable route on *RouteMap*. Some additional studies can check the following references [17], [18], [19], [26], [34].

Multimodel Authentication: With the fast development of information technology, graphical password schemes also encounter various security threats, especially when many attacks can record the devices’ screen or users’ input, e.g., recording attacks [32] and charging attacks [24], [25], [29]. As long as attackers obtained the credentials, they can easily unlock and access the mobile devices. For this reason, many schemes started integrating different biometric approaches [20]. For instance, Meng et al. [23] presented a scheme that combines both touch biometrics with Android unlock, resulting in a multimodel method. In the literature, there is another trend of integrating Android unlock with different touch actions, including Pinch-to-Zoom [14], swipe action [10], [11], double-click action [12], [13], and handwritten [39].

III. OUR APPROACH AND IMPLEMENTATION

In this work, we consider building up a graphical password system based on image selection, as it is the most basic and necessary step in graphical password design. To design our expected system, we have several design goals: 1) the system should be secure against several attacks, such as shoulder-surfing attacks, guessing attacks and brute force attacks; 2) the system should be usable for users; and 3) the system should be robust under a distributed network.

To achieve these goals, we consider: 1) designing the system with multiple rounds of image selection (with probability calculations), aiming to enhance the security against attacks; 2) adopting a certain degree of fault tolerance (with acceptable tolerance range) to improve the system usability; and 3) performing user studies to test the system in an IoT environment (also facilitate the optimization of model settings).

A. Scheme Design

Here we develop RoundImage, a graphical password scheme that requires a user to select images in several rounds. As mentioned earlier, this can help reduce the success rate of being observed or recorded by attackers at one go. Fig. 1 presents the high-level workflow of our RoundImage.

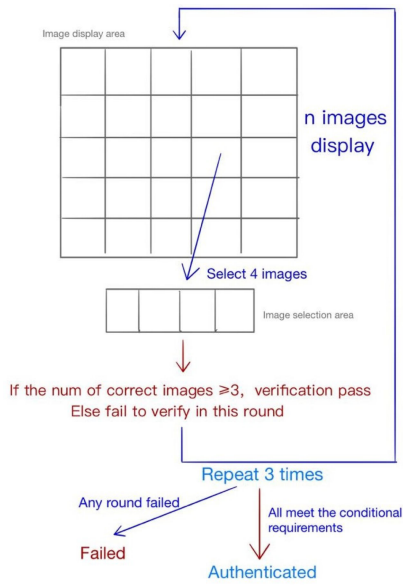


Fig. 1. High-level workflow of our proposed RoundImage.

For RoundImage, we developed a program to help generate images randomly, which learned from a former study [7]. Even for this method, we believe the scheme is still not strong enough to defend against shoulder-surfing attack, as the credentials may be recovered if the attacker can observe all the image selections. For this reason, we develop a novel approach to calculate the probability: that is, a user has to choose four images (cannot select the same image) from the pool. If the number of matched images (refer to the preselected images) is equal or bigger than 3, then we consider the verification is successful. Here, we can set up the image selection rounds, e.g., if we set it to 3, then the user has to be successful in each round—here it means 3 rounds.

a) Matching rate: The main idea of using the matching rate is to estimate the possibility. For three rounds, we have the matching rate at $\geq 75\%$ ($3/4$) for the selected images. In this case, for attackers based on shoulder-surfing actions, though they can record the input process once, it is still not easy for them to guess all the corrected images. Hence, five conditions might be occurred as follows: the first condition—all four images are correct, and the rest conditions—one of the four images is not correct.

However, for such matching method, we can only assure it having a “semi-anti” effect, this is because even if an attacker cannot guess all the correct images, they will obtain the correct one via multiple trials. As just mentioned, we could have five possible conditions under one round of image selection (with four images), then we can have up to 5–125 (5^3) conditions for three rounds of image selection. The password space can be further reduced if the attackers can record more selected images across multiple rounds.

b) Authentication with three rounds: For the current design, we choose three rounds of image selection due to several reasons. First, more rounds of image selection can provide better security against attacks, and we have considered error tolerance so that three rounds are acceptable if we focus more on security strength.

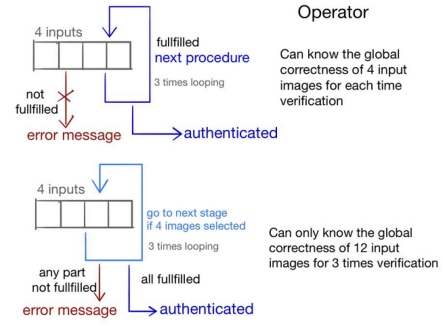


Fig. 2. Authentication method comparison.

Second, our system will move to the next round of image selection even if the selection is wrong for the current round. In this case, it is more difficult for an attacker to figure out which step is wrong, as the attacker can only have an overview guess of all selected images, as shown in Fig. 2.

c) Similar art style: In the aspect of aesthetics, our system built the image pool that will adopt consistent images in style. The main purpose is to remove noticeable differences between images in the pool and enhance the password space. Furthermore, in order to enhance the usability, we consider that all the pool images have to be playful and interesting with consistent style, as it can help reduce the sense of repetition on users’ side [36].

B. Variable Setting and Probability Calculation

To evaluate the password strength, we selected image layer in either 4×4 or 1×4 , which should be more user-friendly than using 5×5 grid directly (this observation was from a presurvey [11]). As we have the “ $\geq 75\%$ matching rate” with four images, we can know the correct images that can appear in each round could be a number between 3 and 16. Hence, the cracking rate under random input can be calculated as below:

the number: 3	probability: 0.007142857142857143
the number: 4	probability: 0.026923076923076925
the number: 5	probability: 0.06318681318681318
the number: 6	probability: 0.11813186813186813
the number: 7	probability: 0.19230769230769232
the number: 8	probability: 0.2846153846153846
the number: 9	probability: 0.3923076923076923
the number: 10	probability: 0.510989010989011
the number: 11	probability: 0.6346153846153846
the number: 12	probability: 0.7554945054945055
the number: 13	probability: 0.8642857142857143
the number: 14	probability: 0.95
the number: 15	probability: 1.0
the number: 16	probability: 1.0

Based on concrete assumptions, we have two basic questions: 1) is it necessary to group different numbers of correct images? and 2) how to decide the patterns of correct images and their distribution? We discuss these issues as below.

The Necessity of Different Numbers of Preselected Images Displayed in Each Round: As depicted in Fig. 3, if the number of correct images in each round is configured to be fixed, then it should obey a one-time binomial distribution. In this case, the attacker has a chance to perform an exhaustive search.

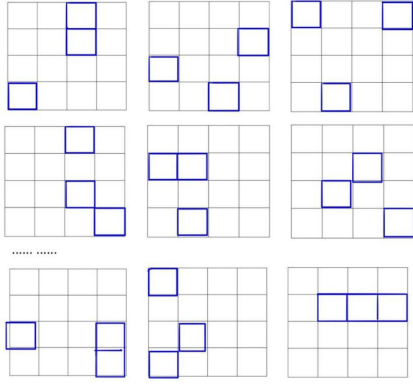


Fig. 3. Number of correct images for each round can be set to a fixed value of 3.

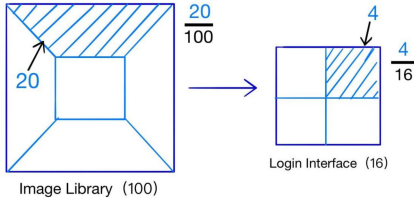


Fig. 4. Inequality between the ratio of preselected images and the entire image pool.

Also, given the fixed number, we can adopt a discrete probability distribution that provides stronger password space. Here we can have two conditions: the first condition—fixed probability and the second condition—uniform distributed probability. Under the same situation, the more patterns we have, the smaller probability to be cracked. More analysis details can refer to our former study [1].

To Decide the Pattern Distribution of Correct Images: Then we have a question about the pattern distribution. If we use a random distribution: $4/16$, it would become challenging as the required resources can increase exponentially. While if attackers can make enough login trials, they should be able to guess the frequency of image display of all images. Here it is possible to have another cracking approach, as we know the display ratio and the total ratio should be: $4/16$ and $20/100$, respectively. As described in Fig. 4, the display ratio is bigger than the total ratio, so that attackers can guess: the correct images should have a higher frequency rate.

We can compute the probability of a single image to be selected as:

- 1) The probability of preselected images: $(1/20) \times (4/16) = 1.25\%$
- 2) The probability of non preselected images: $(1/80) \times (12/16) = 0.9375\%$

In such case, the probability between the above two conditions are noticeable. If an attacker is able to collect more images for analysis, they could have a chance to build up a database of ‘hot-spot’ images, which can be used for a dictionary attack, rather than a simple brute-force attack.

To reduce the success rate of being cracked, the probability of the above two conditions should be equal. Here we can assume the displayed images are 16 each round and the total

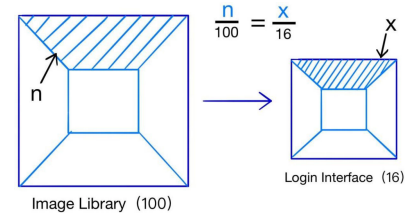


Fig. 5. Schematic diagram of the ratios $n/100$ and $x/16$.

TABLE I
POSSIBILITY $P(c)$ WITH DIFFERENT VALUES OF n

n (/100)	20	21	22	25
$P(c)$	0.011942	0.0164479	0.021140	0.034455
$P(c)^3$	1.703065e-06	4.449698e-06	9.447457e-06	4.09045e-05

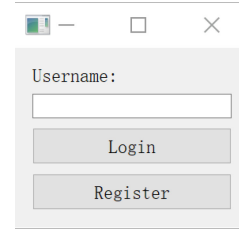


Fig. 6. Interface of our RoundImage.

number of images is 100. Denote x and n as the average number of correct images each round and the total number of correct images. We can have $x/16$ and $n/100$, which have to be equal. Please check Fig. 5.

Given the task by $x/16 = n/100$, we can compute the relevant variables. The details of calculations can refer to our former study [1]. The possibilities according to different values of n can be available in Table I.

C. System Implementation

It is clear that a typical graphical password system includes: user interface, image pool and database. The interface is important to users so that they can more easily interact with the system. Image pool contains the images used for registration and authentication step. The database records the user accounts and relevant graphical credentials created by users.

Fig. 6 shows the interface of our designed RoundImage. Users have to first register their credentials and then authenticate themselves. In particular, Fig. 7 shows an interface for registration, where users have to decide preselected (correct) images at this stage. For the registration, we can see up to 20 images (5×4) will be shown each round. A user can choose a total of 5 images, and afterwards, the system can automatically distribute the images for each round. For example, our system can provide four rounds with 80 images (4 rounds $\times$ 5 images each round), and a user has to select 20 images in total.

To authenticate, as shown in Fig. 8, the user needs to enter the username and then choose four images from each round (up to 16 images will be shown each round). After three rounds of image selection, the system will check whether the user is legitimate or not.

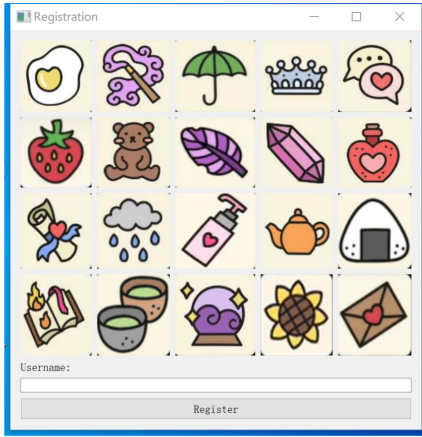


Fig. 7. Interface of system registration.



Fig. 8. Interface of system login.

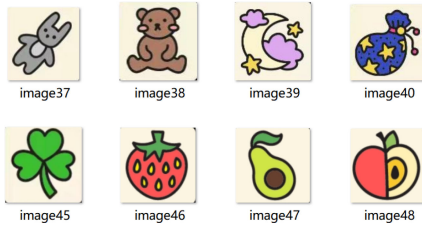


Fig. 9. Several images from the image pool.

Images Used in the System: Our system considers the effect of similar art style, which may affect the password space and the potential user experience. For our scheme, we adopted the images from a game called “3 Tiles.”¹ Each image has a pixel with 150×150 (see Fig. 9). In practical usage, our system can be easily adjusted to use a new image database, and all images can be replaced with others. It is the same for the image pixel, a high pixel rate can make a clearer image, but it may require more time for displaying the images, especially in a network environment. A balance should be made for this purpose.

For the image theme, it covers various common things in our life, including plants, desserts and fruits. We believe this



Fig. 10. Examples of similar distracters in the image pool.

TABLE II
INFORMATION ABOUT ALL PARTICIPANTS IN THE USER STUDY

Information	Male	Female	Occupation	Male	Female
Age < 25	10	13	University Students	18	19
Age 25-40	10	11	Faculty&Staff	8	7
Age 40-65	10	6	Business People	4	4

can help users to remember their created credentials, due to the leverage of existing knowledge [3]. To increase the difficulty of cracking, our system also includes some similar images that share a common characteristic. Fig. 10 shows some examples, e.g., checking the two images with strawberries. The main idea is that users can easily remember a correct image than the attackers. In this case, even if attackers can observe the practical input process, they may input a wrong image.

IV. USER STUDY

In this section, we introduce our user studies with the aim of exploring the performance of our RoundImage scheme. A total of 60 common phone uses were recruited, including 80% Android phone users (only using an Android phone) and 20% hybrid users (using both Android phone and iPhone). In the evaluation, our first user study required users to perform our tasks in a PC, and our second user study required users to use our system via smartphones (in order to form an IoT environment). We mainly used Chi-square tests in our result analysis, and adopted a value of $\rho < 0.05$ to decide whether the results are statistically significant.

The basic information about participants is summarized in Table II. It is visible that we have a balanced number: 30 males and 30 females, ranged from 20–65 ages. The participants have a diverse background from students, university staff or faculty members, and business people. Every attendee can obtain a \$70 gift voucher when they complete the study. The study processes have obtained an approval from participants and IRB approval from the institute.

A. First Study

In this study, we required all participants to use our scheme in a PC, under two different implementation options: 1) the first one with two rounds of image selection and 2) the second one with three rounds of image selection. We randomly divided all participants into two groups (30 participants each group): Group-1 with the scheme using two rounds of image selection and Group-2 with the scheme using three rounds of image selection.

Study Steps: Before the formal start, we provided a detailed document to explain our study goals and the rules about data collection and privacy. Every participant could have three trials

¹<https://www.appyoulove.com/3tiles>

TABLE III
SUCCESS RATE IN THE PHASES OF CONFIRMATION, LOGIN AND RETENTION FOR THE FIRST STUDY

Phase	Group-1: The scheme with two rounds	Group-2: The scheme with three rounds
Confirmation	285/300 (95.0%)	276/300 (92.0%)
Login	281/300 (93.7%)	278/300 (92.7%)
Retention	273/300 (91.0%)	268/300 (89.3%)

to get familiar with the system, and then all the steps would be performed in our lab environment. The detailed study steps are summarized as below.

- 1) *Step 1 (Registration Phase)*: Participant has to register to RoundImage.
- 2) *Step 2 (Confirmation Phase)*: Participant has to confirm the credential for ten times.
- 3) *Step 3 (Distributed Memory)*: A paper-based finding task is provided to distract attention for 10 min.
- 4) *Step 4 (Login Phase)*: Participant has to log into the system for ten times.
- 5) *Step 5 (Feedback Form)*: A question form is given to participants.
- 6) *Step 6 (Retention)*: After three days, all participants are invited to come back and log into the system for ten times.
- 7) *Step 7 (Feedback Form)*: A question form is given to participants about the system usage.

Study Results: In the study, a number of 300 trials were collected for each phase of confirmation, login and retention. Table III summarizes the success rate for each phase under Group-1 and Group-2.

- 1) *Confirmation Phase*: It is visible that Group-1 has a higher success rate of 95% than Group-2 with 92%. Though there is a difference but it is not significant. The main reason is easily to understand: for two rounds of image selection, it is easier for users to remember all the correct images.
- 2) *Login Phase*: It is observed that both groups could achieve a similar success rate of 93.7% and 92.7%, respectively. In our informal interview, most participants believed that the scheme is usable.
- 3) *Retention Phase*: After three days, we invited all participants to return and input the credentials again. There was a decrease on the success rate, e.g., Group-1 could reach a rate of 91% and Group-2 could reach a rate of 89.3%. The difference is not significant.

In this study, we found that participants could perform better under the scheme with two rounds of image selection. This is understandable as they can remember less. Table IV shows the time consumption (TC) and standard division (SD) between these two groups. Similarly, we can observe that the average TC is 16.3 s and 20.4 s for Group-1 and Group-2. The SD under Group-2 was also higher than that under Group-1. Hence, we can say the scheme with two rounds of image selection is more usable than the scheme with three rounds of image selection.

B. Second Study

In this study, we aim to test the performance of RoundImage on smartphones—one kind of typical IoT devices. Also, we

TABLE IV
TC AND SD IN THE LOGIN (FIRST STUDY)

Time	Group-1	Group-2
TC (s)	16.3	20.4
SD (s)	3.8	4.2

TABLE V
SUCCESS RATE IN THE PHASES OF CONFIRMATION, LOGIN AND RETENTION FOR THE SECOND STUDY

Group-A:	RoundImage (Two rounds)	Double Patterns
Confirmation	287/300 (95.7%)	289/300 (96.3%)
Login	285/300 (95.0%)	290/300 (96.7%)
Retention	278/300 (91.7%)	281/300 (93.7%)
Group-B:	RoundImage (Three rounds)	Double Patterns
Confirmation	282/300 (94.0%)	285/300 (95.0%)
Login	280/300 (93.3%)	288/300 (96.0%)
Retention	271/300 (90.3%)	282/300 (94.0%)

consider one relevant work called *Double Patterns* [8] in the comparison. To further explain, the scheme of *Double Patterns* needs a user to input two Android unlock patterns for authentication.

Study Steps: Similar to the first user study, we randomly divided all participants into two groups (30 participants each group): Group-A with the scheme using two rounds of image selection, and Group-B with the scheme using three rounds of image selection. All participants would compare our RoundImage with *Double Patterns*. All the participants used our provided phone (Samsung Galaxy Note) during the study.

Every participant could have three trials to get familiar with the system, and then all the steps would be performed in our lab environment. The study steps are summarized as below.

- 1) *Step 1 (Registration Phase)*: Participant has to register to RoundImage and Double Patterns.
- 2) *Step 2 (Confirmation Phase)*: Participant has to confirm the credentials for ten times for both RoundImage and Double Patterns.
- 3) *Step 3 (Distributed Memory)*: A paper-based finding task is provided to distract attention for 10 min.
- 4) *Step 4 (Login Phase)*: Participant has to log into the system for ten times.
- 5) *Step 5 (Feedback Form)*: A question form is given to participants.
- 6) *Step 6 (Retention)*: After three days, all participants are invited to come back and log into both RoundImage and Double Patterns for ten times.
- 7) *Step 7 (Feedback Form)*: A question form is given to participants about the system usage.

Study Results: It is the same, we could collect 300 trials for each phase of confirmation, login and retention under two

TABLE VI
TC AND SD IN THE LOGIN (SECOND STUDY)

Time	Group-A: Our Scheme	Group-A: Double Patterns
TC (s)	16.7	13.2
SD (s)	4.1	3.8
Time	Group-B: Our Scheme	Group-B: Double Patterns
TC (s)	19.7	14.1
SD (s)	4.2	4.9

schemes. Table V describes the success rate for each phase under Group-A and Group-B.

- 1) *Confirmation Phase*: It is found that participants in both Group-A and Group-B could perform very similarly, e.g., the success rate is 95.7% versus 96.3%, and 94.0% versus 95.0%, respectively. During our informal interview, participants considered both schemes are usable, but Double Patterns could be more easily remembered.
- 2) *Login Phase*: The results are similar to the confirmation phase, the success rate is 95.0% versus 96.7% under Group-A, and 93.3% versus 96.0% under Group-B. Though there is a noticeable difference between the rates, it is not significant.
- 3) *Retention Phase*: In this phase, it is found the rate for both groups was decreased. It is 91.7% versus 93.7% under Group-A and 90.3% versus 94.0% under Group-B. It is interesting to observe the result is not significant under Group-A but is significant under Group-B. In our informal interview, Group-B participants told that it is easier to forget the credentials under RoundImage than Double Patterns.

Based on the results, it is found that both our RoundImage scheme and Double Patterns are usable in general, as participants could perform confirmation and login with a similar success rate. During our informal interview, we also confirmed such observations. For retention, we noticed that the difference might be significant between Double Patterns and our scheme with three rounds of image selection. This is because some participants could easily forget their credentials under RoundImage, this requires further improvements over our scheme. However, the difference might be not significant under our scheme with two rounds of image selection.

Table VI presents the TC and SD between these two groups and two schemes. We notice that participants required less time to complete RoundImage with two rounds of image selection than three rounds, and it is easy to understand. For Group-A, we found that the time difference is small, and most participants could complete the whole process in 13–17 s. For Group-B, it is obvious that participants needed more time for RoundImage than Double Patterns. This shows that Double Patterns can have better user experiences than RoundImage with three rounds.

C. Security Against Attacks

In this part, we aim to evaluate the schemes under attacks, such as brute force attack and shoulder-surfing attack. In practice, as both RoundImage and Double Patterns adopt

TABLE VII
BRUTE FORCE ATTACK ON ROUNDIMAGE

Cracking rate	With one round	With two rounds	With three rounds
Group-1	20%	4%	0
Group-2	15%	5%	1%
Group-A	16%	2%	0.5%
Group-B	22%	2%	0

TABLE VIII
SHOULDER-SURFING ATTACK ON ROUNDIMAGE AND DOUBLE PATTERNS

Cracking rate	RoundImage (two rounds)	RoundImage (three rounds)	Double Patterns
Group-1	35%	25%	60%
Group-2	33%	15%	68%
Group-A	40%	20%	55%
Group-B	35%	16%	65%

a two-step process to complete the login, it is easily to understand that a brute force attack (or guess attack) would be hard.

Brute Force: First, we conducted a test on our RoundImage under brute force attack. In this case, we selected 2 credentials randomly and asked the other participants (excluding the one who created the credential) to guess the credentials for five times. Table VII presents the results.

We considered several conditions: RoundImage with one round, with two rounds and with three rounds. From the table, it is found that there was a high possibility for the scheme to be cracked with only one round. With two rounds of image selection, the cracking rate can decrease to 2–5%. With three rounds of image selection, the cracking rate is very close to 0–1%. It indicates that more rounds of image selection can lead to higher security levels. In practice, we need to make a balance between security and usability.

Shoulder-Surfing: Then we considered a shoulder-surfing attack on both RoundImage and Double Patterns. Here we assume an attack can observe the whole process of inputting the credential, but they cannot video-record the whole process. The cracking rate is depicted in Table VIII.

It is visible that the cracking rate is very high for Double Patterns, as the attackers can observe the input process and understand the unlock patterns. However, for our RoundImage, the attackers still need to guess the correct images. We found that the cracking rate is 33–40% under our scheme with two rounds of image selection, while the rate can be further decreased to 15–25% with three rounds of image selection. The results demonstrated that our scheme with three rounds can provide much better security than Double Patterns. In practice, we need to consider concrete scenarios and select suitable RoundImage schemes (with two rounds or three rounds of image selection).

D. User Feedback

In our study, we could collect two forms about participants' feedback. Ten-point Likert scales were used for each question, where 1-score indicates strong disagreement and 10-score indicates strong agreement. Table IX describes the main questions and the average scores.

TABLE IX
MAJOR QUESTIONS AND AVERAGE SCORES FROM THE PARTICIPANTS

Questions (Group-1)	Average Scores
1. It is easy to log into RoundImage	8.6
2. The time consumption is acceptable for RoundImage	7.4
3. It is easy to remember the credentials for RoundImage	8.1
4. RoundImage with two rounds is more secure than Android unlock pattern	8.9
5. You would like to use RoundImage in practice	8.2
Questions (Group-2)	Average Scores
1. It is easy to log into RoundImage	8.4
2. The time consumption is acceptable for RoundImage	6.9
3. It is easy to remember the credentials for RoundImage	7.5
4. RoundImage with three rounds is more secure than Android unlock pattern	9.2
5. You would like to use RoundImage in practice	7.8
Questions (Group-A)	Average Scores
1. It is easier to log into Double Patterns than RoundImage	4.5
2. The time consumption of Double Patterns is better than RoundImage	6.2
3. It is easier to remember the credentials for Double Patterns than RoundImage	3.1
4. Double Patterns scheme is more secure than RoundImage with two rounds of image selection	4.1
5. You would like to use RoundImage in practice	7.6
Questions (Group-B)	Average Scores
1. It is easier to log into Double Patterns than RoundImage	6.1
2. The time consumption of Double Patterns is better than RoundImage	7.2
3. It is easier to remember the credentials for Double Patterns than RoundImage	5.3
4. Double Patterns scheme is more secure than RoundImage with three rounds of image selection	3.4
5. You would like to use RoundImage in practice	5.2

- 1) *Group-1*: It is visible that most participants believed RoundImage (two rounds) is usable, as the login process is acceptable to them with a score of 8.6. Then, most of them also considered the TC is acceptable with a score of 7.4. Here it depends on personal recommendation, some may prefer a much shorter login time. Then most participants considered it is not hard to remember the credentials of RoundImage, but it needs some practice. As compared with the security of Android unlock pattern, we could find that most participants believed our RoundImage is more secure, as it adopts two rounds of input. Lastly, most participants considered to use RoundImage in practice with a score of 8.2.
- 2) *Group-2*: It is found that participants gave a score of 8.4 to RoundImage (three rounds), indicating that the scheme usage is acceptable. While there are many participants considered the TC should be reduced, resulting in a score of 6.9. Then a score of 7.5 was received regarding the credential memory, most participants believed it is still not very hard to remember but needs more efforts. For security, we saw a much higher score of 9.2, as most participants believed three rounds of image selection could bring the scheme to a high security level. This observation corresponds to our results in Table VIII. In the end, more than half participants were still willing to try this scheme in practice.
- 3) *Group-A*: For this group, we compared the scheme performance between RoundImage (two rounds) and Double Patterns. It is found that most participants believed both schemes are usable, no much difference, but most of them considered Double Patterns may require less time for login (with a score of 6.2). For memory, participants believed both schemes are similar, as it is not hard to remember our selected images

and created patterns. For security, participants believed RoundImage (two rounds) should be more secure than Double Patterns, as it is not easy to identify all correct images at one go. Many participants would be willing to use RoundImage.

- 4) *Group-B*: For this group, we compared the scheme performance between RoundImage (three rounds) and Double Patterns. From the results, we found that most participants believed Double Patterns should be easier for login, this is because the use of three rounds seems a bit time consuming. This feeling has been confirmed in the second question with a score of 7.2, where most participants considered the TC of RoundImage (three rounds) is a bit high. While for the security, much more participants believed RoundImage (three rounds) is more secure than Double Patterns, with a low score of 3.4. In the end, we still have around half participants would like to try this scheme in practice.

Overall, we found that our RoundImage scheme is usable by most participants and they are willing to try the scheme in practice. For the TC, RoundImage still needs to get improved, but it can provide a better security level (either two rounds or three rounds) than Double Patterns. Hence, we need to consider which option should be used in a concrete scenario (depending on the security requirement).

V. VALIDATION AND DISCUSSION

In this section, we further conduct two additional user studies (AUS) between our scheme and some traditional graphical password schemes based mainly on image selection. Then we discuss the open challenges in this field.

TABLE X
SUCCESS RATE IN THE PHASES OF CONFIRMATION, LOGIN AND
RETENTION FOR THE ADDITIONAL STUDIES

AUS-1:	RoundImage (three rounds)	CD-GPS scheme
Confirmation	188/200 (94.0%)	184/200 (92.0%)
Login	185/200 (92.5%)	180/200 (90.0%)
Retention	179/200 (89.5%)	172/200 (86.0%)
AUS-2:	RoundImage (three rounds)	CCP scheme
Confirmation	187/200 (93.5%)	186/200 (93.0%)
Login	186/200 (93.0%)	184/200 (92.0%)
Retention	183/200 (91.5%)	180/200 (90.0%)

A. Additional User Studies

In our previous evaluation, there is a possibility that memorizing unlock patterns may require less effort than memorizing a bunch of pictures. Thus, we performed two AUS to explore this issue. Based on the scheme popularity and implementation availability, we selected two schemes: CD-GPS scheme [16] and Cued Click-Points (CCPs) [4]. The former one is a hybrid scheme, where users have to select 4 images in a sequence from an image pool and then click-draw on one image. The latter is a click-based scheme, where users have to choose one point on a set of images in a sequence (a total of 5 images).

We followed the same steps in our previous user studies, while the main differences are 1) we set the retention phase as one week and 2) we set distributed time as 30 min. We had 40 participants in total (the people are different from our previous studies), which means 20 persons in each study group via random selection (named AUS-1 and AUS-2).

The results are presented in Table X. We could collect 200 trials for each phase of confirmation, login and retention under two schemes, respectively. It is found that participants performed a bit better under our scheme (with three rounds) compared with CD-GPS scheme, while the performance was similar between our scheme and CCP. The results validated our observations in our previous studies.

B. Open Challenges

Based on our study results and feedback, our RoundImage scheme can be usable and more secure as compared with the Double Patterns. It indicates some important benefits, but some improvements are also needed.

- 1) *TC*: As referred by many participants, our RoundImage needs to further reduce its TC. For example, many of them considered two rounds of image selection is more reasonable and acceptable than three rounds. To make a balance between usability and security, we can limit the image selection in the three rounds in order to improve its usability (e.g., reducing the TC).
- 2) *User Sample*: In our evaluation, we have involved 100 participants, who have been divided into different groups in several user studies. We have obtained promising results and the future plan is to further validate the performance by recruiting more participants (e.g., with more participants and groups).
- 3) *Scheme Under Attacks*: In our work, we have tested the security of our RoundImage (two rounds and three

rounds) under both brute-force attack and shoulder-surfing attack. The results indicated that our scheme could provide better security than Android unlock and Double Patterns. In our future work, we plan to test the security under an even stronger attack—video recording attack and examine the security level.

- 4) *Human Effects*: During our studies, we found that the average training time (before the study) for our scheme and Double Patterns is around 10 min, as their operations are intuitive. In contrast, CD-GPS scheme and CCP scheme may need around 20 min for user training, since most users are not familiar with their operations. For system resources, all schemes can be deployed in a typical laptop (e.g., Intel Core i5-7200 CPU@2.50 GHz). While in our future work, it can be an important topic to examine the user training and testing time among different related schemes (which is also an open challenge).
- 5) *User Guidelines*: Login TC is an open challenge for existing graphical password schemes [3]. In our evaluation, we collected the feedback from 50 participants (randomly selected) about how to reduce the required time for registration. There are two main approaches: 1) try to select preferred color plus favorite character(s) or 2) try to select favorite character(s) in an order (e.g., in a story order). These tips can be presented to users and after they get familiar with the scheme, the registration time will be greatly reduced.
- 6) *Long-Term Performance*: The previous studies have already proven that humans can remember graphical credentials easier and longer than textual passwords, so very few related studies actually conduct an observation with long-term performance (e.g., retention over months). Based on different design methods of graphical passwords, users may have various experiences in remembering their credentials. For example, in some schemes, they may need a heavier memory load and more cognitive activities for recognizing and picking up pictures based on memories. We consider this is an important question and plan to investigate it in our future study.
- 7) *Diverse Network Environment*: The same as similar studies, it is an open challenge while important to demonstrate the scheme performance and reliability in diverse IoT environments, e.g., popular IoT applications. We consider this is an important direction that requires more case studies and simulations in further work.

In addition to the above challenges, data privacy is also a big challenge on how to protect users' data, such as encryption of schemes, secure storage of image pools, and compliance with data protection regulations (e.g., GDPR). It is worth noting that graphical password schemes can be enhanced in a practical network by using lightweight algorithms, edge computing, and decentralized authentication protocols.

To encourage and attract more users to be involved with graphical password schemes, there is also a need to enhance user education, design proper incentive mechanisms and integrate the schemes with popular applications. Further, it is

important that the scheme design and interface can accommodate the requirements from senior people with different abilities, as well as provide guidelines for senior people to improve the system usability.

VI. CONCLUSION

In this work, we developed RoundImage, a graphical password scheme based on several rounds of image selection. Selecting images from a pool is the most basic and necessary step in a graphical password system. To enhance the usability, we also included matching rate and error tolerance for RoundImage. In the evaluation, we first performed two user studies with 60 participants: the first one to explore the initial performance between RoundImage with two rounds and three rounds of image selection. The second one aims to compare the performance between our RoundImage and the scheme of Double Patterns. It is found participants could perform well with our RoundImage, whereas there is a great need to further decrease the time consumption for RoundImage with three rounds of image selection. We further tested the security of RoundImage and Double Patterns under attacks, and found that our RoundImage could be much more secure than Double Patterns. In our additional studies with 40 new participants, the results validated our observations compared with two relevant graphical password schemes.

It is worth noting that time consumption is a potentially limiting factor for many graphical password schemes. In our future work, we plan to perform larger studies to explore our scheme performance (e.g., long-term performance) in practice, and examine the security of our scheme under stronger attacks, such as video recording attack. Further, we plan to consider conducting a larger comparison with more similar schemes.

REFERENCES

- [1] X. Qin and W. Li, "A graphical password scheme based on rounded image selection," in *Proc. 5th Int. Conf. Sci. Cyber Security*, 2023, pp. 97–114.
- [2] A. J. Aviv, K. Gibson, E. Mossop, M. Blaze, and J. M. Smith, "Smudge attacks on smartphone touch screens," in *Proc. 4th USENIX Conf. Offensive Technol.*, 2010, pp. 1–7.
- [3] R. Biddle, S. Chiasson, and P. C. Van Oorschot, "Graphical passwords: Learning from the first twelve years," *ACM Comput. Surv.*, vol. 44, no. 4, pp. 1–41, 2012.
- [4] S. Chiasson, P. C. van Oorschot, and R. Biddle, "Graphical password authentication using cued click points," in *Proc. ESORICS*, 2007, pp. 359–374.
- [5] S. Chiasson, E. Stobert, A. Forget, R. Biddle, and P. C. Van Oorschot, "Persuasive cued click-points: Design, implementation, and evaluation of a knowledge-based authentication mechanism," *IEEE Trans. Dependable Secure Comput.*, vol. 9, no. 2, pp. 222–235, Mar./Apr. 2012.
- [6] N. Chakraborty, V. S. Anand, and S. Mondal, "Towards identifying and preventing behavioral side channel attack on recording attack resilient unaided authentication services," *Comput. Security*, vol. 84, pp. 193–205, Jul. 2019.
- [7] R. Dhamija and A. Perrig, "Deja Vu: A user study using images for authentication," in *Proc. 9th USENIX Security Symp.*, 2000, pp. 1–15.
- [8] T. Forman and A. Aviv, "Double patterns: A usable solution to increase the security of android unlock patterns," in *Proc. ACSAC*, 2020, pp. 219–233.
- [9] I. Jermyn, A. Mayer, F. Monrose, M. K. Reiter, and A. D. Rubin, "The design and analysis of graphical passwords," in *Proc. 8th Conf. USENIX Security Symp.*, 1999, pp. 1–14.
- [10] W. Li, J. Tan, W. Meng, Y. Wang, and J. Li, "SwipeVLock: A supervised unlocking mechanism based on swipe behavior on smartphones," in *Proc. ML4CS*, 2019, pp. 140–153.
- [11] W. Li, J. Tan, W. Meng, and Y. Wang, "A swipe-based unlocking mechanism with supervised learning on smartphones: Design and evaluation," *J. Netw. Comput. Appl.*, vol. 165, Sep. 2020, Art. no. 102687.
- [12] W. Li, Y. Wang, J. Tan, and N. Zhu, "DCUS: Evaluating double-click-based unlocking scheme on smartphones," *Mobile Netw. Appl.*, vol. 27, no. 1, pp. 382–391, 2022.
- [13] W. Li, J. Tan, and N. Zhu, "Double-X: Towards double-cross-based unlock mechanism on smartphones," in *Proc. IFIP Int. Conf. ICT Syst. Security Privacy Prot.*, 2022, pp. 412–428.
- [14] W. Li, T. Glerup, J. Tan, and Y. Wang, "A security enhanced android unlock scheme based on pinch-to-zoom for smart devices," *IEEE Trans. Consum. Electron.*, vol. 70, no. 1, pp. 3985–3993, Feb. 2024.
- [15] W. Meng, "Graphical authentication," in *Encyclopedia of Cryptography, Security and Privacy*, S. Jajodia, P. Samarati, and M. Yung, Eds., Cham, Switzerland: Springer, 2021.
- [16] Y. Meng, "Designing click-draw based graphical password scheme for better authentication," in *Proc. IEEE NAS*, 2012, pp. 39–48.
- [17] Y. Meng and W. Li, "Evaluating the effect of tolerance on click-draw based graphical password scheme," in *Proc. ICICS*, 2012, pp. 349–356.
- [18] Y. Meng and W. Li, "Evaluating the effect of user guidelines on creating click-draw based graphical passwords," in *Proc. RACS*, 2012, pp. 322–327.
- [19] Y. Meng, W. Li, and L.-F. Kwok, "Enhancing click-draw based graphical passwords using multi-touch on mobile phones," in *Proc. IFIP Int. Inf. Security Conf.*, 2013, pp. 55–68.
- [20] W. Meng, D. S. Wong, S. Furnell, and J. Zhou, "Surveying the development of biometric user authentication on mobile phones," *IEEE Commun. Surveys Tuts.*, vol. 17, no. 3, pp. 1268–1293, 3rd Quart., 2015.
- [21] W. Meng, "RouteMap: A route and map based graphical password scheme for better multiple password memory," in *Proc. NSS*, 2015, pp. 147–161.
- [22] W. Meng, W. Li, L. Jiang, and L. Meng, "On multiple password interference of touch screen patterns and text passwords," in *Proc. ACM CHI Conf. Human Factors Comput. Syst.*, 2016, pp. 4818–4822.
- [23] W. Meng, W. Li, D. S. Wong, and J. Zhou, "TMGuard: A touch movement-based security mechanism for screen unlock patterns on smartphones," in *Proc. ACNS*, 2016, pp. 629–647.
- [24] W. Meng, W. H. Lee, Z. Liu, C. Su, and Y. Li, "Evaluating the impact of juice filming charging attack in practical environments," in *Proc. ICISC*, 2017, pp. 327–338.
- [25] W. Meng, F. Fei, W. Li, and M. H. Au, "Harvesting smartphone privacy through enhanced juice filming charging attacks," in *Proc. ISC*, 2017, pp. 291–308.
- [26] W. Meng, W. Li, L.-F. Kwok, and K.-K. R. Choo, "Towards enhancing click-draw based graphical passwords using multi-touch behaviours on smartphones," *Comput. Security*, vol. 65, pp. 213–229, Mar. 2017.
- [27] W. Meng, W. Li, W. Lee, L. Jiang, and J. Zhou, "A pilot study of multiple password interference between text and map-based passwords," in *Proc. ACNS*, 2017, pp. 145–162.
- [28] W. Meng, W. Lee, M. H. Au, and Z. Liu, "Exploring effect of location number on map-based graphical password authentication," in *Proc. ACISP*, 2017, pp. 301–313.
- [29] W. Meng, L. Jiang, Y. Wang, J. Li, J. Zhang, and T. Xiang, "JFCGuard: Detecting juice filming charging attack via processor usage analysis on smartphones," *Comput. Security*, vol. 76, pp. 252–264, Jul. 2018.
- [30] W. Meng, L. Jiang, K.-K. R. Choo, Y. Wang, and C. Jiang, "Towards detection of juice filming charging attacks via supervised CPU usage analysis on smartphones," *Comput. Electr. Eng.*, vol. 78, pp. 230–241, Sep. 2019.
- [31] D. L. Nelson, V. S. Reed, and J. R. Walling, "Pictorial superiority effect," *J. Exp. Psychol. Human Learn. Memory*, vol. 2, no. 5, pp. 523–528, 1976.
- [32] D. Nyang et al., "Two-thumbs-up: Physical protection for PIN entry secure against recording attacks," *Comput. Security*, vol. 78, pp. 1–15, Sep. 2018.
- [33] "Passfaces." Accessed: May 1, 2024. [Online]. Available: <http://www.realuser.com/>.
- [34] P. Ray, D. Gir, W. Meng, and S. Hore, "GPOD: An efficient and secure graphical password authentication system by fast object detection," *Multimedia Tools Appl.*, vol. 83, pp. 1–50, Dec. 2023.
- [35] R. N. Shepard, "Recognition memory for words, sentences, and pictures," *J. Verbal Learn. Verbal Behav.*, vol. 6, no. 1, pp. 156–163, 1967.

- [36] R. Setchi and O. K. Asikhia, "Exploring user experience with image schemas, sentiments, and semantics," *IEEE Trans. Affect. Comput.*, vol. 10, no. 2, pp. 182–195, Apr.–Jun. 2019.
- [37] X. Suo, Y. Zhu, and G. S. Owen, "Graphical passwords: A survey," in *Proc. ACSAC*, 2005, pp. 463–472.
- [38] H.-M. Sun, Y.-H. Chen, C.-C. Fang, and S.-Y. Chang, "PassMap: A map based graphical-password authentication system," in *Proc. ASIACCS*, 2012, pp. 99–100.
- [39] L. Wang, W. Meng, and W. Li, "Towards DTW-based unlock scheme using handwritten graphics on smartphones," in *Proc. IEEE MSN*, 2021, pp. 486–493.
- [40] S. Wiedenbeck, J. Waters, J.-C. Birget, A. Brodskiy, and N. Memon, "PassPoints: Design and longitudinal evaluation of a graphical password system," *Int. J. Human-Comput. Studies*, vol. 63, nos. 1–2, pp. 102–127, 2005.
- [41] J. Yan, A. Blackwell, R. Anderson, and A. Grant, "Password memorability and security: Empirical results," *IEEE Security Privacy*, vol. 2, no. 5, pp. 25–31, Sep./Oct. 2004.
- [42] T. Zhou, L. Liu, H. Wang, W. Li, and C. Jiang, "PassGrid: Towards graph-supplemented textual shoulder surfing resistant authentication," in *Proc. Int. Symp. Security Privacy Soc. Netw. Big Data*, 2019, pp. 251–263.